

SOP – Passwort-Reset & Account-Recovery (CFlux)

Version: 1.0 · Stand: 2026-07-13 · Verantwortlich: IT-Support / Anwendungs-Admin

Regelt das Zurücksetzen von Passwörtern und die Wiederherstellung von Zugängen – für Selbstbedienung durch Benutzer und für Support-gestützte Fälle.

1. Zweck

Sichere, nachvollziehbare Wiederherstellung des Zugangs, ohne Sicherheits- oder Datenschutzrisiken (kein Passwort-Versand im Klartext, keine Weitergabe ohne Identitätsprüfung).

2. Funktionsweise im System

CFlux besitzt einen integrierten, sicheren Reset-Prozess ([docs/PASSWORD_RESET.md](#)):

- Reset-Token als **SHA-256-Hash** in der DB gespeichert.
- **1 Stunde** gültig, **einmalige** Verwendung (danach gelöscht).
- **E-Mail-Enumeration-Schutz**: immer gleiche Antwort, egal ob E-Mail existiert.
- Alle Aktionen werden im **Audit-Log** protokolliert.
- Endpunkte: `POST /api/auth/request-password-reset`, `POST /api/auth/verify-reset-token`, `POST /api/auth/reset-password`.
- Passwortänderung im eingeloggten Zustand: `POST /api/users/change-password`.

3. Standardfall: Self-Service-Reset (Benutzer)

1. Login-Seite → „Passwort vergessen?“.
2. E-Mail-Adresse eingeben → System versendet Reset-Link (1 Std. gültig).
3. Benutzer öffnet Link, setzt neues Passwort (Mindestlänge 6 Zeichen).
4. Weiterleitung zum Login; alter Token ist verbraucht.

Benutzer immer zuerst auf den Self-Service verweisen – kein manueller Eingriff nötig.

4. Support-Fall: Reset-Mail kommt nicht an / kein Zugriff

1. **Identität prüfen** (Rückruf über bekannte Nummer, Vorgesetztenbestätigung o. Ä.). Niemals allein auf E-Mail-Anfrage hin zurücksetzen.
2. Prüfen: Ist das Konto **aktiv**? (deaktivierte Konten erhalten keinen Zugang – siehe SOP Benutzer- & Zugriffsverwaltung).
3. E-Mail-Adresse im Benutzerprofil korrekt? Ggf. Tippfehler korrigieren (Änderung dokumentieren).
4. E-Mail-Versand prüfen (Backend-Logs, Spam-Filter, Mail-Dienstleister).
5. Erst danach: Admin stößt Reset an bzw. setzt ein temporäres Passwort und erzwingt Änderung beim nächsten Login.
6. Vorgang dokumentieren (wer, für wen, Grund, Identitätsprüfung, Datum).

5. Admin-/Notfallzugang verloren

- Ist noch ein anderer **ADMIN** vorhanden → dieser setzt das betroffene Konto zurück.
- Ist **kein** Admin mehr verfügbar (Notfall), direkt in der DB die Rolle/den Zugang wiederherstellen:

```
# Beispiel: bestehenden Benutzer zum Admin machen
docker exec -it timetracking-db psql -U timetracking -d timetracking \
  -c "UPDATE users SET role = 'ADMIN' WHERE email =
  'admin@firma.tld';"
```

Anschließend über die App ein sicheres Passwort setzen. Direkten DB-Eingriff dokumentieren und nur durch autorisiertes Personal (IT-Betrieb).

6. Sicherheitsregeln

- Passwörter **nie** per E-Mail/Chat im Klartext versenden.
- Temporäre Passwörter nur über sicheren Kanal, mit erzwungener Änderung.
- Nach mehreren fehlgeschlagenen Resets oder verdächtigem Muster: → **SOP Security Incident Response** prüfen.
- Bei Verdacht auf Konto-Kompromittierung: Konto deaktivieren und ggf. **JWT_SECRET** rotieren (invalidiert alle Sessions).

7. Referenzen

- [docs/PASSWORD_RESET.md](#)
- SOP Benutzer- & Zugriffsverwaltung, SOP Security Incident Response
- Betriebs-SOP ([docs/SOP-BETRIEB.md](#))